

Incident Summary

1)Title Of the Incident

WAF: - Malicious File Upload (Ticket No: -CS-0214)

2)Incident Details

- **Receive Time:** - 2/16/2025 23:38
- **Source IP:** -
- **Destination IP:** -
- **Destination Port:** - 443
- **Site Name:** -
- **Matched string:** - PUT /uploads/shell.php
- **HTTP Method:** - PUT
- **Threat Name:** - Malicious File Upload
- **Action Taken:** - Allowed
- **Severity:** - Critical
- **URL:** - /admin
- **Direction:** - Inbound

3)Description Of Incident

On **February 16, 2025, at 23:38**, the WAF detected a **Malicious File Upload attempt** from targeting () over **HTTPS (443)**. The attacker tried to upload a PHP web shell using: PUT /uploads/shell.php

The activity was marked **Critical severity** but the WAF **Allowed** the request, which was directed at the /admin endpoint. This could potentially enable remote control of the server if successful.

4)Investigation Summary

- **Source IP:**
 - Not part of the internal organization.
 - **Reputation Check (AbuseIPDB):** No malicious history reported.
 - **ISP:** Microsoft Limited
 - **Location:** Redmond, Washington, United States

Splunk Findings

- **Total Events Observed: 227**
 - **Firewall:** 76 events
 - **IPS:** 76 events
 - **WAF:** 75 events → **59 Allowed, 16 Blocked**

Key Allowed Events

HTTP Smuggling Attempt

- a. **Threat Name:** HTTP Smuggling
- b. **URL:** /admin
- c. **HTTP Method:** POST
- d. **Response Code:** 302 (Redirect)

Malicious File Upload Attempt

- a. **Threat Name:** Malicious File Upload
- b. **URL:** /admin
- c. **HTTP Method:** PUT
- d. **Response Code:** 200 (OK)

Analysis

- The attacker attempted multiple exploit techniques (**HTTP Smuggling** and **Malicious File Upload**) against the **/admin** of
- Of particular concern is the **file upload attempt (PUT /uploads/shell.php)** which returned a **200 OK response**, suggesting that the malicious PHP file may have been successfully uploaded to the server.
- The **HTTP Smuggling attempt** was redirected (302), but the activity still indicates active probing of web application weaknesses.
- Since the WAF action was **Allowed**, both requests were forwarded to the application, increasing the risk of compromise.

5)Action Taken

- **Blocked the source IP (48.207.20.146)** at the firewall to prevent further attacks.
- Requested the **WAF team** to enforce stricter blocking for **file upload and HTTP smuggling payloads**.

- Application Team to review the uploaded script “upload/shell.php” and remove it from web server and check if the script was executed on server itself if Yes, please perform the further analysis if server is compromised.